Propuesta de mejora sobre Ciberseguridad

Compañía: LexCorp

Contexto

La noche del 20 al 23 de junio de 2021, LexCorp fue víctima de un *malware* (ataque) que afectó a sus servidores (Windows Server 2003/2012) y equipos de usuario (Windows 7/Windows 10) de toda la infraestructura.

Tras identificar todos los dispositivos infectados, el área de soporte técnico tomó las siguientes acciones:

Acciones tomadas

- Guardaron una muestra del malware.
- Apagaron, el mismo día 23 de septiembre, las máquinas que se habían identificado como afectadas durante el incidente.
- En las máquinas que disponían de copia de seguridad (back-up), restauraron al estado correspondiente al día 19 de septiembre (fecha de último backup disponible previo al ataque). Solo un 10% del Parque contaba con backup.
- El 24 de septiembre, LexCorp solicita los servicios de un analista de ciberseguridad para analizar una muestra y emitir recomendaciones para su infraestructura de red y mejorar su postura de ciberseguridad.
- LexCorp solicita la elaboración de un informe de análisis del ataque, que tipo de malware es y el vector de ataque para aportar más detalles sobre el incidente y el nivel de compromiso derivado del mismo.

Objetivo

- Analizar acciones llevadas a cabo por el área de soporte técnico.
- Hipótesis más detallada teniendo cuenta la entrega anterior
- Solución propuesta de mejora:
  - Una implementación de solución.
  - Revisión del perímetro con buenas prácticas, al menos 3 (tres).
  - Implementación de programa/s.
  - Ejecución de ese/esos programa/s.

Análisis de Acciones tomadas

Acciones	Bien/Mal	Porque
1ra acción	Bien	Por que permite al equipo hacer un análisis completo y detallado sobre lo que paso y poder encontrar vulnerabilidades.
2da acción	Mal	Si bien detiene la propagación, se pierde evidencia crítica en RAM. Lo correcto es aislar de la red sin apagar para realizar un volcado de memoria. Usando herramientas como FTK Imager o DumpIt
3ra acción	Mal	Todas deberían incluir backup, o al menos los equipos que guardan información importante.
4ta acción	Bien	Tomaron acciones de inmediato.
5ta acción	Bien	Para saber que deben corregir y cómo actuar en el caso que vuelva a suceder.

Informe de muestra de análisis e hipótesis.

Nombre de la muestra	Fecha de Análisis	OS utilizado para el análisis	Tipo de malware identificado
modificar_usuarios.ps1	23/05/2025	Win10 64bit	Ransomware-as-a-Service (RaaS) o Loader

1er informe detallado:
https://docs.google.com/document/d/1qXLdBBPiEY1mSWPDaKz25oMQPGhx1Crxi6TdEK_LuBM/edit?usp=sharing

En el link podrán encontrar tanto el análisis dinámico, informe sobre la muestra, y una conclusión al final del mismo.

Solución- Propuesta de mejora

Mejores prácticas:

Las mismas serán divididas en 3 categorías: Usuario, Dispositivos y Redes.

Esto se hace con el fin de poder eliminar vulnerabilidades tanto humanas como de los dispositivos y redes en sí.

Solución- Propuesta de mejora

Usuarios:

- Capacitar a los empleados sobre ciberseguridad para que aprendan a distinguir el phishing sobre mails sin peligro alguno.
- Que sepan reconocer que links son seguros y cuáles no.
- Hacer pruebas semanales/mensuales (dependiendo el área de trabajo) para comprobar si realmente han adquirido la capacidad de saber identificar cada situación.
- Advertirles que cada dispositivo tendrá una configuración distinta dependiendo de su área de trabajo, ya que en las distintas áreas de la empresa hay empleados que necesitan acceso a ciertas páginas o funciones y otras no necesitan esos accesos.

Solución- Propuesta de mejora

Cómo se implementan estas prácticas?

- Para implementar estas prácticas en los usuarios se harán capacitaciones y pruebas. Los usuarios que no pasen las pruebas deberán visualizar nuevamente la capacitación con el objetivo de poder aprender qué fallos tuvo a la hora de realizar esa prueba. Las pruebas pueden ser, enviarles mails sospechosos y ver si logran identificarlos, links con archivos descargables que sean maliciosos, anuncios raros para comprobar si los abren o que sucede.

Solución- Propuesta de mejora

Dispositivos:

- Actualizar el sistema operativo de los dispositivos para poder tener las últimas o de las últimas actualizaciones del sistema elegido, ya que en versiones anteriores hay vulnerabilidades que no han sido tratadas e incluso las nuevas versiones incluyen mejores configuraciones y tienen actualizaciones constantes.
- Añadir restricciones a los dispositivos dependiendo del área a la cual están asociados. Por ejemplo: a la gente del área de Administración restringirles la consola de comandos o Powershell ya que ellos no necesitan usar eso para sus funciones, y si dejarles esa función a las personas que están en el área IT.
- A la hora del back-up recomiendo implementar la regla 3-2-1: 3 copias de seguridad, en 2 soportes distintos, con 1 copia fuera de línea (*offline*) para que el ransomware no la pueda cifrar. Para ello recomiendo utilizar el programa Veeam Backup & Replication.

Solución- Propuesta de mejora

Cómo se implementan estas prácticas?

- Para que estas prácticas se puedan llevar a cabo el equipo de soporte técnico deberá realizar dichas acciones para evitar que vuelvan a ocurrir accidentes como el sucedido.
- En el caso de que la empresa no cuente con los recursos suficientes para poder actualizar los sistemas operativos a su versión más reciente o con la capacidad de hacer backups a aquellos dispositivos con información confidencial, se recomienda que actualice los sistemas operativos a la versión más reciente que se pueda (para incluir las soluciones a las vulnerabilidades de windows 7 por ejemplo) y en el caso de los backups. Añadir backups a aquellos dispositivos con sistema operativo antiguo ya que es el más expuesto a ataques.

Solución- Propuesta de mejora

Redes:

- Recomiendo actualizar el Windows Server a la versión 2022, ya que la versión que tienen ya no recibe mejoras de seguridad lo cual deja a la empresa expuesta a muchos ataques.
- Implementar micro-segmentación: esto permite dividir la red en capas para que un atacante no tenga acceso a toda la red en un posible intento de ataque.
- Incluir verificación doble factor (MFA): esto es como tener otro método de seguridad además de la contraseña, permite que si el atacante llegará a descubrir la contraseña necesitará otra verificación gracias al MFA.

Solución- Propuesta de mejora

Cómo se implementan estas prácticas?

- Estas prácticas se deben implementar de inmediato por que al igual que los Usuarios, la red esta expuesta a internet y a millones de personas. Se debe implementar por medio ya sea por el área de soporte técnico o contratar a personas que lo sepan implementar. Esto se puede realizar por las páginas de windows y de los Firewall como Fortinet.

Solución- Propuesta de mejora

En qué orden se implementan estas prácticas?

1. Redes: ya que es el medio de conexión con internet. Si la empresa no tiene su red y servidores protegidos lo más probable es que se vea atacada y expuesta a múltiples ataques.
2. Usuarios: el ser humano por su propia inocencia y confianza suele ser la parte con más vulnerabilidades por explotar. Por lo tanto se debe capacitar a los Usuarios para reducir esas vulnerabilidades.
3. Dispositivos: una vez capacitados los usuarios y mejoradas las redes, procedemos con los dispositivos ya que son la última parte de la organización la cual puede ser afectada, para llegar a los dispositivos el atacante o ingresa por una vulnerabilidad en la red o un error humano.

Solución- Propuesta de mejora

IDS / IPS (Sistemas de Detección y Prevención)

Se sugieren estas configuraciones:

- Detección de Anomalías en PowerShell: Configurar firmas para detectar y bloquear el uso de parámetros de evasión de políticas de ejecución como EPbypass (Execution Policy Bypass), técnica clave utilizada en este ataque.
- Monitoreo de Persistencia: Alertar sobre la creación de tareas programadas sospechosas. En este caso, el sistema de detección debería haber marcado como alerta la creación de la tarea "UpdateChecker" mediante schtasks.exe. Para ello se instalaran agentes del programa Wazuh en los servidores de Windows 2022 para hacer un monitoreo.
- Prevención de Desactivación de Seguridad: Bloquear la ejecución o descarga de herramientas conocidas para "cegar" el sistema, específicamente DefenderRemover.exe, el cual fue invocado para deshabilitar Windows Defender.
- Detección de "Beaconing": Configurar el IDS para identificar patrones de consultas DNS repetitivas a dominios comunes (como google.com o bing.com) que el malware usa como pruebas de conectividad antes del cifrado.

Solución- Propuesta de mejora

Medidas de Protección de Perímetro (Firewall)

- Bloqueo de Repositorios Públicos no autorizados: Restringir el acceso desde servidores y estaciones de trabajo a dominios como github.com, raw.githubusercontent.com y sourceforge.net para los empleados que no son de áreas en relación con la tecnología. Se configuraran perfiles de *Web Filtering* para el bloqueo de GitHub y SourceForge y se activará la licencia de *SSL Inspection* para analizar el tráfico cifrado
- Filtrado de Salida: Implementar políticas de "denegación por defecto" (Default Deny), permitiendo únicamente conexiones salientes a dominios de infraestructura crítica y verificada (como los servicios de actualización de Microsoft identificados).
- Inspección de Tráfico HTTPS: Dado que el malware realiza peticiones web (HTTP/HTTPS) para validación de certificados y obtención de instrucciones, el firewall debe ser capaz de inspeccionar tráfico cifrado para detectar patrones de comunicación con centros de mando (C2).

Conclusión

Las mejoras que se indicaron en las diapositivas anteriores son muy necesarias para que no se vean comprometidos nuevamente los datos tanto de la empresa como los de los clientes que tienen. Es de vital importancia implementarlas cuanto antes para evitar nuevos ataques.

Espero que mi informe les haya sido de utilidad y que puedan implementar las mejoras indicadas.